EXPRESSING IMPACT OF VULNERABILITIES: AN EXPERT-FILLED DATASET AND VECTOR CHANGER FRAMEWORK FOR MODELLING MULTISTAGE ATTACKS, BASED ON CVE, CVSS and CWE

Tomasz Machalewski[1], Marcin Szymanek[2], Adam Czubak[3], and Tomasz Turba[4]

[1]Institute of Computer Science, University of Opole, e-mail: tomek.machalewski@gmail.com
[2]Institute of Computer Science, University of Opole, e-mail: mszymanek@uni.opole.pl
[3]Institute of Computer Science, University of Opole, e-mail: aczubak@uni.opole.pl
[4]Faculty of Computer Science, Opole University of Technology, e-mail: t.turba@po.edu.pl

KEYWORDS

Cybersecurity dataset, Attack graphs, Multistage attack, CVE (Common Vulnerabilities and Exposures), CWE (Common Weakness Enumeration), TI (Technical Impact), CVSS (Common Vulnerability Scoring System).

ABSTRACT

In this work we focus on measuring and attributing impacts to vulnerabilities. We do it in a two-fold way. First, we introduce a concept of Vector Changer – a CVSS-based measure of how successful exploitation of a vulnerability could lead to usage of consecutive vulnerabilities. The consecutive nature being crucial for analysis of multi-stage attacks and creation of attack graphs. Secondly, we present an expert-filled dataset containing CVE-attributed: Technical Impacts, CVSS and Vector Changer. The dataset contains data for 22 CVEs, each filled separately by three experts (66 CVE datapoints total). Each vulnerability has been assessed on four increasing levels of information availability. Finally, we present a lookup table that enables easy attribution of Vector Changers to vulnerabilities. We present initial findings for our dataset and efficiency of our lookup table in respect to the formulated dataset.

INTRODUCTION

While assessing the security of an IT infrastructure, one might encounter an issue of expressing and identifying possible outcomes of an adversary's actions. Further issues arise when considering automation of such processes. To these extents, security researchers have introduced a model of adversary's action known as attack graphs (Konsta et al., 2023). Attack graphs have also been extended with probabilistic component, describing likelihood of adversary's actions – we will not discuss this aspect in this paper. Commonly, while constructing attack graphs an issue of connecting identified system properties into penetration paths arises. There are multiple models, some of them incorporate CVEs (Common Vulnerabilities and Exposures) to describe what is achievable during an attack on a given infrastructure. Connections between CVEs (describing consecutive steps) are constructed using either specific predefined rules or a model of extractable system properties.

To cope with the issue of automatic construction of edges in attack graphs we are introducing a concept of vector changer (VC) - a CVSS-based model of CVE impacts. We also introduce an expert-filled, structured dataset describing outcomes of exploitation of vulnerabilities and some other classical measures (fully described in DATASET section). We made the dataset available at https://github.com/tmachalewski/CVEsImpactDataset.

Defining the impact of vulnerabilities is crucial in cybersecurity, as highlighted by the reviewed literature (Allodi et al., 2017; Zhu, 2023). Understanding these impacts helps prioritize and formulate effective mitigation strategies, ensuring that resources are allocated efficiently to address the most severe threats, thereby enhancing an organization's defence mechanisms.

RELATED WORK AND BACKGROUND

Vulnerabilities found in IT systems and software are a major security threat as they can be exploited and used by malicious actors. Based on data provided by IBM X-Force, the share of incidents resulting from vulnerability exploitation are 26% in 2022, 34% in 2021 and 35% in 2020 ("IBM Security X-Force Threat Intelligence Index 2023," n.d.). The National Vulnerability Database (NVD) is widely recognized as the primary source for standardized vulnerability management information related to a wide array of security vulnerabilities, developed and hosted by the United States Department of Commerce National Institute of Standards and Technology (NIST) (Kuehn et al., 2021). Several other national databases, similar to NVD, provide vulnerability management services worldwide. These include the Chinese National Vulnerability Database (CNNVD, www.cnnvd.org.cn), Russia's Data Security Threats Database (BDU, https://bdu.fstec.ru/), and Japan Vulnerability Notes (JVN, https://jvn.jp/en/), each contributing to a global repository of security vulnerability data.

In this paper we focus on data provided by NIST in NVD which is cataloged using the CVE (Common Vulnerabilities and Exposures) system which offers a standardized approach to cataloging publicly recognized

Communications of the ECMS, Volume 38, Issue 1,
Proceedings, ©ECMS Daniel Grzonka, Natalia Rylko,
Grazyna Suchacka, Vladimir Mityushev (Editors) 2024
ISBN: 978-3-937436-84-5/978-3-937436-83-8(CD) ISSN 2522-2414

vulnerabilities and exposures in information security (Wu et al., 2019). CVE is sponsored by the National Cyber Security Division of the U.S. Department of Homeland Security ("Overview | CVE," n.d.). CVE is linked, in most cases, with the Common Vulnerability Scoring System (CVSS), which is a standardized framework for rating the severity of security vulnerabilities in software and systems. It assigns scores based on factors like exploitability and impact, providing a quantitative measure to prioritize response efforts for different vulnerabilities ("CVSS v4.0 Specification Document," n.d.). The CVE is also linked with Common Platform Enumeration (CPE) which is a standardized method of describing and identifying classes of applications, operating systems, and hardware devices within the cybersecurity realm. CPE facilitates the accurate and consistent description of these entities across different information systems, enhancing interoperability and enabling more effective management of security-related information ("NVD - CPE," n.d.). It is crucial also to note that CVE is linked to CWE, or Common Weakness Enumeration, which is a category system for software weaknesses and vulnerabilities, providing a standardized language for identifying and mitigating software flaws ("CWE - About - CWE Overview," n.d.).

CVE and CVSS challenges

During our investigation into the CVE system, as outlined by the NVD, we encountered numerous publications highlighting a variety of challenges within the CVE and CVSS frameworks. These challenges, varied in their nature, were synthesized from the literature into key thematic areas presented herein. It is crucial for the reader to recognize that this compilation does not exhaustively cover all documented CVE challenges but focuses on those most pertinent and recurrently emphasized in the literature relevant to this study.

Aforementioned thematic areas are:

1. Insufficient Information in Baseline Descriptions. Baseline vulnerability descriptions provided by standard sources, including those in the National Vulnerability Database (NVD), are found to be incomplete for accurate vulnerability assessment. (Allodi et al., 2018a; Anwar et al., 2020; Dobrovoljc et al., 2017; Hans and Brandtweiner, 2022; Kuehn et al., 2021; Spring et al., 2021)
2. Volume and Analysis overwhelm, the metrics may not align with user needs, and the sheer volume of vulnerabilities requiring analysis can overwhelm the institution. (Aranovich et al., 2021; Kuehn et al., 2021)
3. The NVD provides a CVSS score for vulnerabilities, which is intended as a prioritization index. However, this approach has been criticized as ineffective. (Anwar et al., 2020; Aranovich et al., 2021; Hans and Brandtweiner, 2022; Spring et al., 2021; Yang et al., 2020)
4. There is a growing necessity to integrate information from diverse sources, including social media, to provide a more comprehensive and timely understanding of cybersecurity threats. (Aranovich et al., 2021)
5. Information in the CVE and other databases is sometimes out-of-sync or lacks sufficient evidence for timely reproduction and patching of vulnerabilities. (Eitel, 2020; Kuehn et al., 2021; Sommestad et al., 2012)
6. Subjective Perception of Severity. Different organizations may perceive the severity of vulnerabilities differently, leading to variations in prioritization and mitigation approaches. (Allodi et al., 2020, 2018b, 2017; Eitel, 2020; Hans and Brandtweiner, 2022; Russo et al., 2019; Spring et al., 2021; Wang et al., 2020; Wunder et al., 2023)
7. Discrepancy in Expert Assessments. Expert evaluations of vulnerability severity often differ from the CVSS score, leading to discrepancies in the perceived severity of vulnerabilities. (Allodi et al., 2020, 2018b; Hans and Brandtweiner, 2022; Sommestad et al., 2012; Wunder et al., 2023; Yang et al., 2020)
8. Challenges in Addressing Shared and Chained Vulnerabilities: CVSS's one-size-fits-all approach struggles to capture the complexity of shared and chained vulnerabilities. (Spring et al., 2021)

Numerous government bodies require the use of the CVSS for security assessments in security critical domains (Scarfone and Mell, 2009), healthcare technology (Stine et al., 2017) and the credit card sector (Allodi and Massacci, 2017; Ruohonen, 2019). One of the most prominent examples of such requirements is BOD 22-01 which is a directive from CISA aimed at mitigating the risk associated with known vulnerabilities, requiring U.S. federal agencies to quickly address and remediate actively exploited vulnerabilities in their systems. It specifies a list of critical vulnerabilities to be fixed within set timelines to protect critical infrastructure ("BOD 22-01," 2021).

CVE prominence and importance is also expressed by the amount and relevance of institutions listed as CVE-Compatible Products and Services ("CVE - Compatible Products and Services (Archived)," n.d.). The CVE Compatibility Program has been discontinued yet it further shows its vast adaptation in the IT security industry.

CVE, by the adaptation and usage of CVSS, makes an effort to provide structured and unequivocal data for security experts. A great challenge that was undertaken by MITRE to identify, define, and catalog publicly disclosed cybersecurity vulnerabilities has made the process of maintaining IT systems vulnerability-free

easier, but as mentioned earlier, it has potential to provide an even better source of information both for security experts and automated tools for vulnerability detection. As the description provided in every CVE is natural language based and CVSS is a rough generalization of vulnerability parameters, vulnerability detection and mitigation are still a labor-intensive endeavor.

CWE's Common Consequences and Technical Impact

The Common Weakness Enumeration (CWE) framework includes a "Common Consequences" table, which outlines potential outcomes of weaknesses. This table categorizes the consequences by the scope of the security area affected and the technical impact resulting from exploitation. Additionally, it assesses the likelihood of each consequence, which varies depending on the nature of the exploit's impact.

Common Consequences in the Impact section provide a Technical Impact list which in our assessment provides adequate and easily understandable consequences for security professionals. The flaw of the current approach is that a given CVE, with defined CWE, provides generalized Technical Impacts which may or may not occur in that specific case. Nevertheless, Technical Impacts provide defined, categorized and clear information on what can or will happen if a vulnerability is exploited.

This is why we have decided to use the Technical Impact list from CWE to enhance the CVE impact measures. In our approach a team of security experts was asked to assign true or false values to a list of Technical Impacts for a given CVE.

We were unable to find detailed definitions of Technical Impacts. The closest piece of information we found was Enumeration of Technical Impacts available at CWE homepage ("CWE - Enumeration of Technical Impacts," n.d.). During the initial overview of CWE-associated Technical Impacts we noticed not all of them are mentioned on the referenced page. To gather the full list, we acquired all CVEs since 2002 in NVD database ("NVD - Data Feeds," n.d.) and scrapped associated Technical Impacts.

We were still missing the definitions of Technical Impacts. To deal with this issue, we formulated our own definitions and presented them for acceptance to our experts.

The accepted definitions were as follows:

1. **Execute Unauthorized Code or Commands**: This refers to situations where an attacker is able to run arbitrary code or system commands without having the necessary permissions. This often occurs due to vulnerabilities like buffer overflows, injection attacks, or insecure configurations.
2. **Gain Privileges or Assume Identity**: This happens when an attacker is able to escalate their privileges within a system or network, or assume the identity of a legitimate user. It can result from weak authentication, insecure password management, or flaws in a system's access control measures.
3. **Modify Memory**: This impact refers to the alteration of a system's memory by an attacker. Vulnerabilities like buffer overflows, for example, can be exploited to change the values stored in the memory, leading to a variety of potential attacks.
4. **Modify Files or Directories**: Here, an attacker can make unauthorized changes to files or directories within a system, potentially altering the behavior of software, revealing sensitive data, or causing damage to the system.
5. **Modify Application Data**: This refers to unauthorized alterations to an application's data. This could result in changes to how the application operates, or in the corruption or loss of data.
6. **Read Memory**: This means that an attacker is able to read the contents of a system's memory, potentially gaining access to sensitive information stored there.
7. **Read Application Data**: This refers to unauthorized access to an application's data, which could reveal sensitive information or be used to carry out further attacks.
8. **Read Files or Directories**: In this case, an attacker can read the contents of files or directories they should not have access to, potentially revealing sensitive data.
9. **DoS: Crash, Exit, or Restart**: Denial of Service (DoS) attacks that cause a system or application to crash, exit, or restart can make services unavailable to legitimate users, affecting the system's availability.
10. **DoS: Instability**: This type of DoS attack results in unpredictable behavior or instability in a system, making it unreliable for users.
11. **DoS: Resource Consumption (CPU)**: This is a DoS attack that consumes excessive CPU resources, slowing down the system or even causing it to crash due to overload.
12. **DoS: Resource Consumption (Memory)**: Similar to the above, this DoS attack consumes a lot of memory resources, leading to system slow down, instability, or crashes.
13. **DoS: Resource Consumption (Other)**: This refers to a DoS attack that uses up other system resources (like network bandwidth, disk space, etc.), causing similar impacts to the above.
14. **DoS: Amplification**: This refers to a kind of Denial of Service (DoS) attack wherein the attacker sends a small amount of malicious or malformed data that causes the target system to respond with a significantly larger amount of data. Amplification attacks often exploit stateless protocols, causing large volumes of data to be sent to a victim, which overwhelms their resources.

15. **Bypass Protection Mechanism**: This impact occurs when an attacker is able to circumvent security measures such as firewalls, intrusion detection systems, or access controls, leading to unauthorized access or actions within a system.
16. **Hide Activities**: In this scenario, an attacker is able to conduct malicious activities without being detected. They might do this by deleting logs, using stealthy malware, or exploiting vulnerabilities that allow them to evade detection.
17. **Reduce Maintainability**: This impact pertains to vulnerabilities or weaknesses that make a system harder to maintain. This could be due to issues like code obfuscation, spaghetti code, or the use of deprecated libraries and functions. A less maintainable system can be more prone to bugs, more challenging to patch, and more vulnerable to future threats.
18. **Reduce Performance**: Vulnerabilities or misconfigurations can lead to reduced system performance. This might manifest as slower response times, reduced throughput, or increased resource consumption. Reduced performance not only affects user experience but can also indicate underlying security issues.
19. **Reduce Reliability**: This impact indicates that the system becomes less dependable or predictable because of certain vulnerabilities. Systems with reduced reliability might crash unexpectedly, lose data, or exhibit erratic behavior.
20. **Quality Degradation**: This refers to a reduction in the overall quality of the system or application due to vulnerabilities or weaknesses. It encompasses a range of issues from poor user experience, unreliable functionalities, to inherent security vulnerabilities.
21. **Alter Execution Logic**: If an attacker can exploit a vulnerability to alter the intended execution logic of an application, the software can behave in unintended ways. This could lead to unauthorized actions, data leakage, or system crashes.
22. **Varies by Context**: This is a more generic impact and essentially means that the specific impact of a vulnerability or weakness can differ based on the context in which it exists. The surrounding environment, other integrated systems, user interactions, or other variables can influence the exact nature of the impact.
23. **Unexpected State**: Exploiting certain vulnerabilities might push a system or application into an unforeseen state. This unpredictability can lead to crashes, data corruption, or other adverse behaviors.
24. **Other**: This is a catch-all category for impacts that don't fit neatly into the predefined categories. It signifies that there might be unique or less-common consequences arising from certain vulnerabilities or weaknesses.

It is important to note that CWE provides technical impacts that may occur. In many cases because of vulnerability's nature, not all technical impacts suit the vulnerability.
Additionally, as mentioned before, CVE in its current form does not provide capabilities to address the problem of shared and chained vulnerabilities. In some cases, CVEs can be used by a malicious actor in a sequence in which case the impact of a sequential attack would be vastly more critical than exploiting a single vulnerability. In some cases, vulnerability is a gateway which gives the adversary a chance to conduct a well-known attack which leads to furthering negative impact of an attack but not a given vulnerability.

Measures of effects of a successful exploitation

As mentioned in the previous subsection, the CVE fails to provide reliable information on potential consequences of exploitation of a vulnerability. CVSS provides limited information using Impact Metrics incorporated in Base Metric Group. Despite the effort to quantify potential impact of exploitation it is one of commonly mentioned challenges facing CVSS which we described earlier as Subjective Perception of Severity and Insufficient Information in Baseline Descriptions. As a result, security researchers took on the challenge to propose alternative methods for a descriptive yet structured impact or consequence tool.
While the issue of describing effects of successful exploitation of vulnerability is in many cases directly related to attack graphs, an issue of knowing what can be achieved with a vulnerability is present in wider scope of cybersecurity-related activities (Russo et al., 2019). The process of defining outcomes of CVE has been described as both time consuming and requiring expert knowledge (Ozdemir Sonmez et al., 2022; Russo et al., 2019).
While we were able to find substantial amount of material, describing challenges modern CVE faces, in previous section, there are limited resources that tackle the issue of addressing CVE-impact relationship (Ozdemir Sonmez et al., 2022). For enumerating related works associated with expressing effects of vulnerabilities, we performed search in three search engines with combination of specific words.
Our search process provided us with a vast number of publications which undertake the topic of a specific CVE and its exploitation, CVE in general, as a method for enumerating vulnerabilities, its challenges, measures, statistics, and reproducibility. Despite that, the number of scientific papers which explore structured, data driven and unequivocal approach to impact of vulnerability exploitation is shrouded with false positives.
We used the following search engines:

- Google (https://www.google.com/);

- Google Scholar (https://scholar.google.com/);
- Consensus GPT (https://consensus.app/).

While two initial entries are common sources of material used during searches of related material, Consensus GPT is a newer addition to researcher's toolkit and its efficacy is to be determined.

Search queries were formulated, against those search engines, as follows:

1. First, we defined three sets of words:
    a) referring to CVE – "CVE" or "vulnerability";
    b) referring to usage – "real-life", "" (empty string) and "exploit";
    c) referring to impact – "consequences", "impact", "effects", "risks" and "severity".
2. Secondly, we constructed all possible combinations of elements from sets a, b, and c.
3. Finally, we queried search engines with queries formulated in 2.

Example queries were: "CVE real-life consequences", "vulnerability impact" and "vulnerability exploit severity".

Findings were as follows:

1. Impacts are defined with natural language (Russo et al., 2019).
2. Due to the sheer number of CVEs, manual labour is ineffective (Ozdemir Sonmez et al., 2022).
3. For analysis of CVEs, experts are needed (Russo et al., 2019)
4. Even for experts, analysis of complex, multi-stage attacks is difficult (Ozdemir Sonmez et al., 2022).
5. Most tools consider only the reachability of network nodes, rather than effects of vulnerabilities (Ozdemir Sonmez et al., 2022).
6. CVSS is not enough to assess the impacts of vulnerability (Russo et al., 2019).
7. Vulnerability scanners, such as Nessus or OpenVAS, do not provide effects vulnerabilities could have on a system (Russo et al., 2019).
8. Risk assessment requires impacts that vulnerabilities could have on a system (Russo et al., 2019).
9. Security teams are required to evaluate risks derived from vulnerabilities (Russo et al., 2019).

Given those findings, our contributions, in the area of measuring the effects of successful exploitation, are as follows:

1. Effects are defined with structured data.
2. We formulated a dataset that could be used for an automation of analysis of CVEs.
3. An automated analysis could be conducted to lower the workload placed on experts.
4. While not in scope of this article, close relation to attack graphs could make analysis of multi-stage attacks easier.
5. We introduce a dataset containing expert-filled surveys on effects of vulnerabilities.
6. We extend the CVSS framework in areas of defining the effects of vulnerabilities.
7. We provide a measure that could enhance vulnerability scanners with the possibility of enumerating effects of vulnerabilities.
8. We provide security teams with tools to define impact and manage vulnerability risks.

VECTOR CHANGER

Here we are introducing a concept of Vector Changer (VC). VC is a way of representing consequences of successful exploitation of CVE, while also being able to represent preconditions needed for possible exploitation of CVE. Presented further dataset attributes, among other classical concept, VCs to CVEs,

Motivation for Vector Changer's creation

While, highlighted in INTRODUCTION and RELATED WORK AND BACKGROUND sections, the need for expressing consequences of vulnerability has merits of its own, our needs arised from requirements of constructing attack graphs, while not having access to clear ways of assessing consequences of successful exploitation of wide range of CVEs. For attack graphs construction, representing consequences of vulnerability is needed, but is not sufficient to successfully construct attack paths. To achieve construction of attack paths, one also needs prerequisites of CVEs being achieved by exploitation of previous CVEs. Ideally, consequences of downstream vulnerability could be used as a prerequisite for possibility of exploiting another vulnerability. Where some mechanisms scan vulnerability's description for a hand-crafted list of keywords, such solutions are prone to over-narrowing possible consequence pool, while also hardly indicating which vulnerabilities could be used next. VC is based on CVSS, which allows it to be used as both consequences and prerequisites of CVEs, which have CVSS 3.0 or 3.1 defined (though it is easy to generalize it to other versions)

Definition of Vector Changer

While VC could be used separately to express consequences (and prerequisites) of vulnerability and to indicate a node in an attack graph, for the purpose of graphical representation we will limit our definitions to the attack graph environment.

VC is a node in an attack graph, which can be used for representing both consequences and prerequisites of CVE. The general idea behind VC is "which CVEs could be used, if this given CVE has been exploited successfully". Looking from a perspective of processing graph-generation rules, it is sound to define VC separately as a consequence node and as a prerequisite

node. As a prerequisite node, VC takes value of one of CVSS characteristics.
Given four characteristics of exploitability vector of CVSS, there are four basic types of VC nodes:

- Attack Vector (AV) node,
- Attack Complexity (AC) node,
- Privileges Required (PR) node,
- User Interaction (UI) node.

An occurrence of such a node, as a prerequisite, indicates that a specific level of CVSS characteristic must be reached for a CVE to be exploitable. As a consequence node VC also takes value of one of previously mentioned CVSS characteristics. For example, Attack Vector VC could take values of: Network (N), Adjacent (A), Local (L) and Physical (P). Meaning that CVEs with given characteristic of CVSS can now be used. Nonetheless, in the attack graph environment, it is beneficial to define the end goal of an attacker in the context of a single device. To this extent we have defined a fifth VC:

- Exploited (EX) node.

Meaning

The general idea describing VC's meaning is: CVEs with what characteristics could be used next, given successful exploitation of given CVE. While working on attack graphs we noticed that Attack Vector (AV) and Privileges Required (PR) VCs could be used to reflect the level of system compromise an attacker reaches during exploitation of a system. AV and PR VCs were grouped into exploitation VCs.
Attack Complexity (AC) and User Interaction (UI) were used as indicators of environmental factors describing attacker and host user. AC and UI VCs were grouped into environmental VCs.
New exploitation VCs can be acquired during penetration of a system, reflecting compromise of a machine, or gaining higher level of privileges. On the other hand, environmental VCs do not change, as they indicate characteristics that are unlikely to change during a single attack. For example, we used UI VC to indicate how experienced a user of a given machine is. UI has two levels:

- None (N),
- Required (R).

UI VC of value R would indicate that the user is inexperienced and is likely to perform actions that are envisaged by the attacker, for example clicking a link in a phishing email. Value N of UI VC indicates that only CVEs not requiring user interaction are accessible to the attacker.

General rules for acquiring

One of reasons behind creation of VCs was the possibility of streamlining the creation of a model, that would allow to easily provide VC for a given CVE. While having access to experts, we decided to create a transformation matrix, that for a given Technical Impact would be returning corresponding VC. We created four such transformation matrices:

- each expert created his own (for a total of three),
- experts consensually created the fourth matrix.

Transformation matrices are attached to the dataset. The consensual matrix is presented in Table 1.
The measured performance metrics are available at the dataset's repository.

Table 1: The Consensually Agreed Transformation Matrix

	Vector changer								
	AV				PR				
	N	A	L	P	N	L	H	None	Compromised
Execute Unauthorized Code or Commands			x				x		x
Gain Privileges or Assume Identity			x				x		x
Modify Memory			x				x		x
Modify Files or Directories			x				x		x
Modify Application Data			x				x		x
Read Memory			x				x		
Read Application Data			x						
Read Files or Directories			x						
DoS: Crash, Exit, or Restart								x	
DoS: Instability								x	
DoS: Resource Consumption (CPU)								x	
DoS: Resource Consumption (Memory)								x	
DoS: Resource Consumption (Other)								x	
DoS: Amplification								x	
Bypass Protection Mechanism			x				x		
Hide Activities								x	
Reduce Maintainability								x	
Reduce Performance								x	
Reduce Reliability								x	
Quality Degradation								x	
Alter Execution Logic								x	
Varies by Context								x	
Unexpected State								x	
Other								x	
NONE								x	
NOT ENOUGH DATA								x	

DATA SET

Dataset described below is available at https://github.com/tmachalewski/CVEsImpactDataset.
In our study, we detail the process of engaging three cybersecurity experts (Marcin Szymanek, Adam Czubak and Tomek Turba), whose biographies are available at the bio section of this paper, to conduct an independent assessment of various Common Vulnerabilities and Exposures (CVEs) using the Common Vulnerability Scoring System (CVSS) as a reference framework. Each expert was selected based on their extensive experience and proven track record in the field of cybersecurity, ensuring a high level of proficiency and insight into vulnerability assessment.
To maintain the integrity of the evaluation process, the experts were provided with a standardized set of CVEs without the official CVSS scores. They were asked to assign CVSS scores based on their professional judgment, taking into account the severity, impact, and exploitability of each vulnerability. This approach allowed us to compare expert-driven assessments with the official CVSS scores to identify potential discrepancies, biases, or insights that might emerge from the subjective analysis of seasoned professionals.

The experts' evaluations were conducted independently to prevent any potential influence from peer assessments, ensuring that each score reflected the

individual expert's perspective. This process was designed to explore the reliability and consistency of CVSS scores when subjected to expert scrutiny, contributing to the ongoing discourse on the effectiveness of vulnerability scoring systems in accurately representing the risk and severity of cybersecurity threats.

We incorporated an innovative approach to refine the assessment of the impact level for each Common Vulnerabilities and Exposures (CVE) under review. Drawing from the Common Weakness Enumeration (CWE) framework, we specifically focused on the "Technical Impact" factor, which falls under the broader category of "Common Consequences." This facet of the CWE framework provides a structured understanding of the potential technical repercussions stemming from the exploitation of vulnerabilities.

To enhance the accuracy and depth of our vulnerability impact assessments, we tasked our panel of cybersecurity experts with the responsibility of annotating each evaluated CVE with binary indicators (true/false). These indicators were assigned based on the presence or absence of specific technical impacts associated with the vulnerability in question, as delineated by the CWE's "Technical Impact" criteria. This method allowed for a more granulated and precise evaluation of the vulnerabilities' potential to compromise confidentiality, integrity, availability, and other critical aspects of an information system.

By adopting this detailed approach, our aim was to go beyond the conventional assessment methodologies and provide a nuanced perspective on the implications of each CVE. This would enable a more informed and accurate depiction of the vulnerabilities' severity and guide stakeholders in prioritizing remediation efforts effectively. The integration of the CWE's "Technical Impact" criteria into our assessment process is defined by this paper, detailing the guidelines provided to the experts for the annotations and the subsequent analytical procedures employed to interpret these binary indicators in the context of the overall impact assessment.

In the empirical phase of our study, the participating cybersecurity experts were methodically guided to fill out a series of structured spreadsheets tailored to capture a comprehensive array of data points pertinent to each Common Vulnerabilities and Exposures (CVE) under scrutiny. The designated spreadsheets, arranged in a specific sequence—Description, Links, Own Research, Own Research URLs, CWE, and Group CVE—were meticulously designed to facilitate a holistic evaluation of the technical impact, personal CVSS assessments, and the identification of potential vector changers, with the latter being elaborately discussed in a separate section of the paper.

The initial step in this process involved the "Description" sheet, where experts transcribed the official vulnerability descriptions directly from the National Vulnerability Database (NVD). This foundational step aimed to ground the experts' assessments in the established narratives of the vulnerabilities. Subsequently, the "Links" sheet required the experts to delve deeper into the vulnerabilities by exploring the "References to Advisories, Solutions, and Tools" section of the NVD. This exploration was intended to enrich their understanding with more detailed and nuanced information available through external sources linked within the NVD.

Next the cybersecurity experts proceeded to the "Own Research" spreadsheet. In this stage, they leveraged their professional expertise and personal methodologies developed throughout their careers to conduct independent online research on the vulnerabilities. This step was crucial for uncovering additional insights and information beyond what was available in the standard databases, thereby enriching the overall understanding of each vulnerability's nuances and potential impacts.

Upon identifying valuable external sources that augmented the existing knowledge about a vulnerability, the experts documented these resources in the "Own Research URLs" sheet. This procedure ensured a structured accumulation of supplementary information, further expanding the depth of the "Own Research" findings.

Following the independent research phase, the experts engaged with the "Weakness Enumeration" section of the NVD for each vulnerability. Here, they examined the associated Common Weakness Enumeration (CWE) identifiers to gain insights into the fundamental weaknesses underlying the vulnerabilities. This examination was pivotal as it provided an opportunity to reassess and potentially recalibrate their initial assessments in light of the detailed weakness descriptions and classifications provided by the CWE framework.

The final step in the assessment process involved the "Group CVE" sheet, which allowed the experts to identify and catalog vulnerabilities that were related or interconnected, acknowledging the prevalent issue of shared and chained vulnerabilities within the cybersecurity domain. This grouping activity was instrumental in understanding the broader context and potential compound effects of related vulnerabilities, further emphasizing the complexities and challenges in addressing multifaceted cybersecurity threats.

A critical component of our methodology was the meticulous time tracking for the completion of each sheet. This not only provided insights into the labor intensity associated with each segment of the assessment but also highlighted the temporal dynamics of conducting thorough vulnerability evaluations. The documentation of time expenditure was crucial for understanding the practical implications of the assessment process in real-world security operations.

This comprehensive and iterative assessment process, marked by a blend of a structured database analysis and an expert-driven independent research, underscored the dynamic and complex nature of vulnerability assessment.

Our initial findings

As in subsection "CVE and CVSS Challenges", our experts experienced similar problems with CVSS as mentioned earlier regarding Subjective Perception of Severity and Discrepancy in Expert Assessments.

Surveys which the experts have completed showed a significant discrepancy in Exploitability metric values to those provided by NVD. Only in 53% of the cases our experts have, after conducting all the steps of survey (Description, Links, Own research, CWE), reached the same exploitability score as NVD suggests. Additionally, the level of consistency of answers in our expert group was 55%, meaning in 55% of cases experts gave the same answers.

All security experts have changed their initially provided Exploitability score after acquiring additional information. Changes have occurred on average in 24.24% of cases. This means that after getting initial information about an exploit from NVD description section by the time they have gone through links, own research and CWE information in 24.24% of cases a change has occurred.

This is an additional proof that Subjective Perception of Severity and Discrepancy in Expert Assessments is a prevalent problem in the it security community.

All experts completed the survey while being time-measured. It took on average 12 minutes to conduct a full CVE analysis. We believe that if the CVSS was more unequivocal those times could be lowered.

CONCLUSIONS

In this study, we have introduced a novel framework called Vector Changer (VC) to enrich the analysis and modeling of multistage cyber-attacks, leveraging the Common Vulnerabilities and Exposures (CVE), Common Vulnerability Scoring System (CVSS), and Common Weakness Enumeration (CWE). Our approach, centered around the VC concept, offers a nuanced method to quantify and articulate the impacts of vulnerabilities, providing a more dynamic representation crucial for constructing detailed attack graphs.

Our expert-filled dataset, comprising assessments of 22 CVEs by three cybersecurity experts, presents an in-depth look at vulnerabilities' technical impacts, contributing significantly to the field of cybersecurity research. This dataset not only facilitates a deeper understanding of CVE attributes but also aids in the development of more sophisticated and accurate models for predicting and preventing multistage cyber-attacks.

The findings from our study underscore the importance of expert opinion in the assessment of vulnerabilities, revealing notable discrepancies in the exploitability metrics when compared to those provided by the National Vulnerability Database (NVD). This highlights the limitations of current standardized scoring systems like CVSS in capturing the complexity and context-specific nature of vulnerabilities, emphasizing the need for more adaptable and nuanced approaches like the VC framework.

Furthermore, our research demonstrates the potential utility of the VC framework in enhancing the construction and analysis of attack graphs. By offering a method to systematically represent the consequences and prerequisites of exploiting CVEs, the VC framework enables a more detailed and informative depiction of potential attack paths, thereby improving the predictability and prevention of multistage attacks.

Despite the promising outcomes, our work is not without limitations. The reliance on a limited number of experts and CVEs calls for a broader dataset to validate and refine the VC concept further. Additionally, the manual nature of the dataset creation process suggests the potential for automating parts of this process to enhance efficiency and scalability.

In conclusion, the VC framework and the associated expert-filled dataset mark significant advancements in the field of cybersecurity, particularly in the modeling and analysis of multistage attacks. Future research will focus on expanding the dataset, automating the data collection process, and further refining the VC framework to better serve the cybersecurity community in understanding and mitigating the impacts of vulnerabilities.

ACKNOWLEDGEMENTS

This work was supported by the Polish National Centre of Research and Development under the CyberSecIdent Programme within CYBERSECIDENT/489912/IV/NCBR/2021 project.

Authors would like to thank Jacek Kiełbasa and Sebastian Bala for the work they have put in completion of CyberEva project.

REFERENCES

Allodi, L., Banescu, S., Femmer, H., Beckers, K., 2018a. Identifying Relevant Information Cues for Vulnerability Assessment Using CVSS, in: Proceedings of the Eighth ACM Conference on Data and Application Security and Privacy. pp. 119–126. https://doi.org/10.1145/3176258.3176340

Allodi, L., Biagioni, S., Crispo, B., Labunets, K., Massacci, F., Santos, W., 2017. Estimating the Assessment Difficulty of CVSS Environmental Metrics: An Experiment, in: Dang, T.K., Wagner, R., Küng, J., Thoai, N., Takizawa, M., Neuhold, E.J. (Eds.), Future Data and Security Engineering, Lecture Notes in Computer Science. Springer International Publishing, Cham, pp. 23–39. https://doi.org/10.1007/978-3-319-70004-5_2

Allodi, L., Cremonini, M., Massacci, F., Shim, W., 2020. Measuring the accuracy of software vulnerability assessments: experiments with students and professionals. Empir. Softw. Eng.

25, 1063–1094. https://doi.org/10.1007/s10664-019-09797-4
Allodi, L., Cremonini, M., Massacci, F., Shim, W., 2018b. The Effect of Security Education and Expertise on Security Assessments: the Case of Software Vulnerabilities.
Allodi, L., Massacci, F., 2017. Security Events and Vulnerability Data for Cybersecurity Risk Estimation. Risk Anal. 37, 1606–1627. https://doi.org/10.1111/risa.12864
Anwar, A., Abusnaina, A., Chen, S., Li, F., Mohaisen, D., 2020. Cleaning the NVD: Comprehensive Quality Assessment, Improvements, and Analyses.
Aranovich, R., Wu, M., Yu, D., Katsy, K., Ahmadnia, B., Bishop, M., Filkov, V., Sagae, K., 2021. Beyond NVD: Cybersecurity meets the Semantic Web., in: New Security Paradigms Workshop. Presented at the NSPW '21: New Security Paradigms Workshop, ACM, Virtual Event USA, pp. 59–69. https://doi.org/10.1145/3498891.3501259
BOD 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities | CISA [WWW Document], 2021. URL https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities (accessed 2.4.24).
CVE - Compatible Products and Services (Archived) [WWW Document], n.d. URL https://cve.mitre.org/compatible/compatible.html#j (accessed 2.4.24).
CVSS v4.0 Specification Document [WWW Document], n.d. . FIRST — Forum Incid. Response Secur. Teams. URL https://www.first.org/cvss/v4.0/specification-document (accessed 2.4.24).
CWE - About - CWE Overview [WWW Document], n.d. URL https://cwe.mitre.org/about/index.html (accessed 2.4.24).
CWE - Enumeration of Technical Impacts [WWW Document], n.d. URL https://cwe.mitre.org/cwraf/enum_of_ti.html (accessed 2.4.24).
Dobrovoljc, A., Trcek, D., Likar, B., 2017. Predicting Exploitations of Information Systems Vulnerabilities Through Attackers' Characteristics. IEEE Access 5, 26063–26075. https://doi.org/10.1109/ACCESS.2017.2769063
Eitel, A., 2020. Environmental Aware Vulnerability Scoring:, in: Proceedings of the 5th International Conference on Internet of Things, Big Data and Security. Presented at the 5th International Conference on Internet of Things, Big Data and Security, SCITEPRESS - Science and Technology Publications, Prague, Czech Republic, pp. 478–485. https://doi.org/10.5220/0009839104780485
Hans, J., Brandtweiner, R., 2022. BEST PRACTICES FOR VULNERABILITY MANAGEMENT IN LARGE ENTERPRISES: A CRITICAL VIEW ON THE COMMON VULNERABILITY SCORING SYSTEM. Presented at the RISK/SAFE 2022, Rome, Italy, pp. 123–134. https://doi.org/10.2495/SSR220101
IBM Security X-Force Threat Intelligence Index 2023 [WWW Document], n.d. URL https://www.ibm.com/reports/threat-intelligence (accessed 2.4.24).
Konsta, A.-M., Spiga, B., Lafuente, A.L., Dragoni, N., 2023. A Survey of Automatic Generation of Attack Trees and Attack Graphs.
Kuehn, P., Bayer, M., Wendelborn, M., Reuter, C., 2021. OVANA: An Approach to Analyze and Improve the Information Quality of Vulnerability Databases, in: Proceedings of the 16th International Conference on Availability, Reliability and Security. Presented at the ARES 2021: The 16th International Conference on Availability, Reliability and Security, ACM, Vienna Austria, pp. 1–11. https://doi.org/10.1145/3465481.3465744
NVD - CPE [WWW Document], n.d. URL https://nvd.nist.gov/products/cpe (accessed 2.4.24).
NVD - Data Feeds [WWW Document], n.d. URL https://nvd.nist.gov/vuln/data-feeds (accessed 2.4.24).
Overview | CVE [WWW Document], n.d. URL https://www.cve.org/About/Overview (accessed 2.4.24).
Ozdemir Sonmez, F., Hankin, C., Malacaria, P., 2022. Attack Dynamics: An Automatic Attack Graph Generation Framework Based on System Topology, CAPEC, CWE, and CVE Databases. Comput. Secur. 123, 102938. https://doi.org/10.1016/j.cose.2022.102938
Ruohonen, J., 2019. A look at the time delays in CVSS vulnerability scoring. Appl. Comput. Inform. 15, 129–135. https://doi.org/10.1016/j.aci.2017.12.002
Russo, E.R., Di Sorbo, A., Visaggio, C.A., Canfora, G., 2019. Summarizing vulnerabilities' descriptions to support experts during vulnerability assessment activities. J. Syst. Softw. 156, 84–99. https://doi.org/10.1016/j.jss.2019.06.001
Scarfone, K., Mell, P., 2009. An analysis of CVSS version 2 vulnerability scoring, in: 2009 3rd International Symposium on Empirical Software Engineering and Measurement. Presented at the 2009 3rd International Symposium on Empirical Software Engineering and Measurement (ESEM), IEEE, Lake Buena Vista, FL, USA, pp. 516–525. https://doi.org/10.1109/ESEM.2009.5314220

Sommestad, T., Holm, H., Ekstedt, M., 2012. Estimates of success rates of remote arbitrary code execution attacks. Inf. Manag. Comput. Secur. 20, 107–122. https://doi.org/10.1108/09685221211235625

Spring, J., Hatleback, E., Householder, A., Manion, A., Shick, D., 2021. Time to Change the CVSS? IEEE Secur. Priv. 19, 74–78. https://doi.org/10.1109/MSEC.2020.3044475

Stine, I., Rice, M., Dunlap, S., Pecarina, J., 2017. A cyber risk scoring system for medical devices. Int. J. Crit. Infrastruct. Prot. 19. https://doi.org/10.1016/j.ijcip.2017.04.001

Wang, W., Shi, F., Zhang, M., Xu, C., Zheng, J., 2020. A Vulnerability Risk Assessment Method Based on Heterogeneous Information Network. IEEE Access 8, 148315–148330. https://doi.org/10.1109/ACCESS.2020.3015551

Wu, X., Zheng, W., Chen, X., Wang, F., Mu, D., 2019. CVE-Assisted Large-Scale Security Bug Report Dataset Construction Method. J. Syst. Softw. 160, 110456. https://doi.org/10.1016/j.jss.2019.110456

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F., Benenson, Z., 2023. Shedding Light on CVSS Scoring Inconsistencies: A User-Centric Study on Evaluating Widespread Security Vulnerabilities.

Yang, H., Park, S., Yim, K., Lee, M., 2020. Better Not to Use Vulnerability's Reference for Exploitability Prediction. Appl. Sci. 10, 2555. https://doi.org/10.3390/app10072555

Zhu, Q., 2023. Enhancing vulnerability scoring for information security in intelligent computers. Int. J. Intell. Netw. 4, 253–260. https://doi.org/10.1016/j.ijin.2023.09.002

BIOGRAPHIES

TOMASZ MACHALEWSKI is a PhD student at the University of Opole, where he applies recent advancements of graph machine learning methods to analysis of multistage network attacks. After completion of his participation in CyberEva project, he has joined Relativity sp. z o. o., an e-discovery product company, as a software engineer, where, among other things, he applies natural language processing algorithms to analyse documentation of litigation cases. He has participated in multitude of software engineering and R&D projects in areas of cybersecurity, MLOps, machine learning, and AI in computer games. His research interests include machine learning on graphs, natural language processing and cybersecurity.

MARCIN SZYMANEK is a cybersecurity expert with extensive experience in both academia and industry, particularly at the University of Opole and Orange Polska. He is co-author and scientific worker in CyberEva cybersecurity project. His expertise encompasses network security, protocols, and ICT solutions implementation. Szymanek has contributed to research in network optimization and security, evidenced recognized certifications and course completions such as CEH, CCNA, CCNP and PRINCE2, ITIL, AgilePM highlighting his broad skills in project management, networks and cybersecurity.

ADAM CZUBAK holds the position of Assistant Professor at the Institute of Computer Science within the University of Opole. He earned his Ph.D. in technical sciences, specializing in computer networks. As the Head of the IT Security Research Group, he oversees the CyberEva: Cybersecurity R&D Project. Dr. Czubak's interests lie at the intersection of research and practical time, he analyzes corporate and consumer computer network infrastructure, exploring security solutions and technologies.

TOMASZ TURBA is a cybersecurity specialist at Securitum company. He cooperated with numerous institutions as a security consultant, pentester and GDPR inspector. He has extensive experience as a CSIRT leader. Author of several innovative cybersecurity training courses. Speaker during international cybersecurity conferences and award winner for best IT security publications. Co-author of "Introduction to cybersecurity" book.